

ETHICAL HACKING INTERNSHIP

TechBiz Security

Week 5 · Task 15

Brute Force & Authentication Attacks

Hydra · rockyou.txt · DVWA Brute Force Module

Intern Name	Mah Noor
TryHackMe Username	Mahnnorchaudary
Submission Date	September 21, 2026
Environment	DVWA (Windows) · Hydra (Kali Linux) · rockyou.txt
Target	DVWA Brute Force Module — localhost

1. Introduction — Brute Force Attacks

A brute force attack is a trial-and-error method used to obtain credentials by systematically attempting every possible combination of passwords until the correct one is found. When combined with wordlists like `rockyou.txt` — which contains over 14 million real-world passwords leaked from previous data breaches — brute force becomes highly efficient against weak passwords.

Hydra is the industry-standard online password cracking tool used by penetration testers worldwide. It supports over 50 protocols including HTTP, FTP, SSH, RDP, SMB, and more — making it extremely versatile for authentication attack simulations.

Key concepts covered in this task:

- Online brute force attacks against web login forms
- Using `rockyou.txt` wordlist for dictionary-based attacks
- Hydra syntax and parameter configuration for HTTP-GET forms
- Why weak passwords are catastrophic for security
- Defense strategies against brute force attacks

2. TryHackMe — Room Completions

2.1 Hydra Room

The TryHackMe Hydra room was completed, covering:

- Introduction to Hydra and its supported protocols
- Using Hydra against HTTP POST and GET login forms
- SSH brute forcing with Hydra
- Wordlist selection and optimization
- Interpreting Hydra output to identify valid credentials

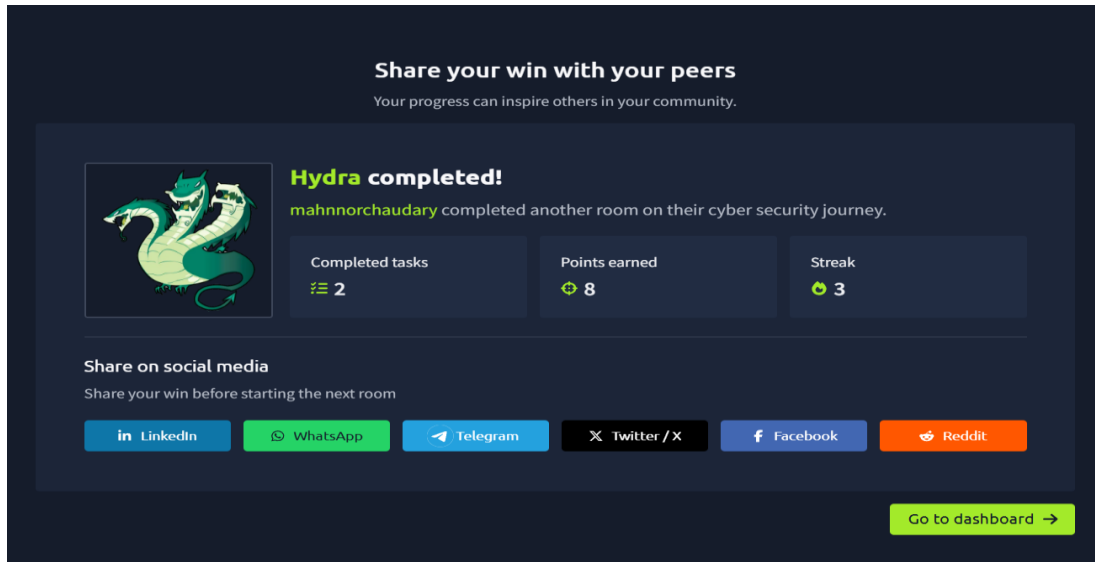


Figure 1: TryHackMe Hydra room completed — mahnnorchaudary (8 points)

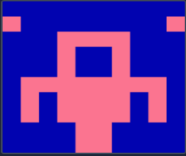
2.2 Brute It Room

The TryHackMe Brute It room was completed, covering:

- Reconnaissance to identify login endpoints
- Brute forcing a web login with Hydra
- Cracking obtained password hashes using John the Ripper
- SSH access using cracked credentials
- Privilege escalation after initial access

Share your win with your peers

Your progress can inspire others in your community.



Brute It completed!

mahnnorchaudary completed another room on their cyber security journey.

Completed tasks

 4

Points earned

 330

Streak

 3

Share on social media

Share your win before starting the next room

in LinkedIn

 WhatsApp

 Telegram

 Twitter / X

 Facebook

 Reddit

Go to dashboard →

Figure 2: TryHackMe Brute It room completed — mahnnorchaudary (330 points)

3. Practical Exercise — DVWA Brute Force

3.1 Lab Setup & Target

- Target: DVWA Brute Force module — localhost/dvwa/vulnerabilities/brute/
- DVWA Security Level: Low (no lockout, no CAPTCHA)
- OS: Windows 10 (DVWA host) + Kali Linux (attack machine)
- Tool: Hydra v9.x with rockyou.txt wordlist
- Username targeted: admin (known from DVWA setup)

3.2 Wordlist — rockyou.txt

rockyou.txt is the most famous password wordlist in cybersecurity, containing 14,344,391 real passwords leaked from the RockYou.com breach in 2009. It is pre-installed in Kali Linux at:

```
/usr/share/wordlists/rockyou.txt
```

If compressed, it is extracted with:

```
gunzip /usr/share/wordlists/rockyou.txt.gz
```

This wordlist is effective because it contains real passwords people actually use — making it devastating against systems without proper password policies.

3.3 Hydra Command & Syntax

The following Hydra command was used to brute force the DVWA login form:

```
hydra -l admin -P /usr/share/wordlists/rockyou.txt 127.0.0.1 \
http-get-form "/dvwa/vulnerabilities/brute/:username=^USER^\
&password=^PASS^&Login=Login:Username and/or password incorrect."
```

Command breakdown:

- -l admin — sets the username to "admin" (single user, lowercase L)
- -P rockyou.txt — specifies the password wordlist file
- 127.0.0.1 — target IP address (localhost where DVWA is running)
- http-get-form — specifies HTTP GET form attack module
- ^USER^ and ^PASS^ — Hydra placeholders replaced with each attempt
- "Username and/or password incorrect." — failure string to detect wrong passwords

3.4 Result — Credentials Found

Hydra successfully identified valid credentials. The result was also confirmed directly in the DVWA interface where the URL revealed the successful login parameters:

```
localhost/dvwa/vulnerabilities/brute/?username=admin&password=password&Login=Login#
```

The URL confirms: username=admin, password=password — both visible in the GET request, demonstrating not only weak password usage but also insecure transmission of credentials via GET parameters.

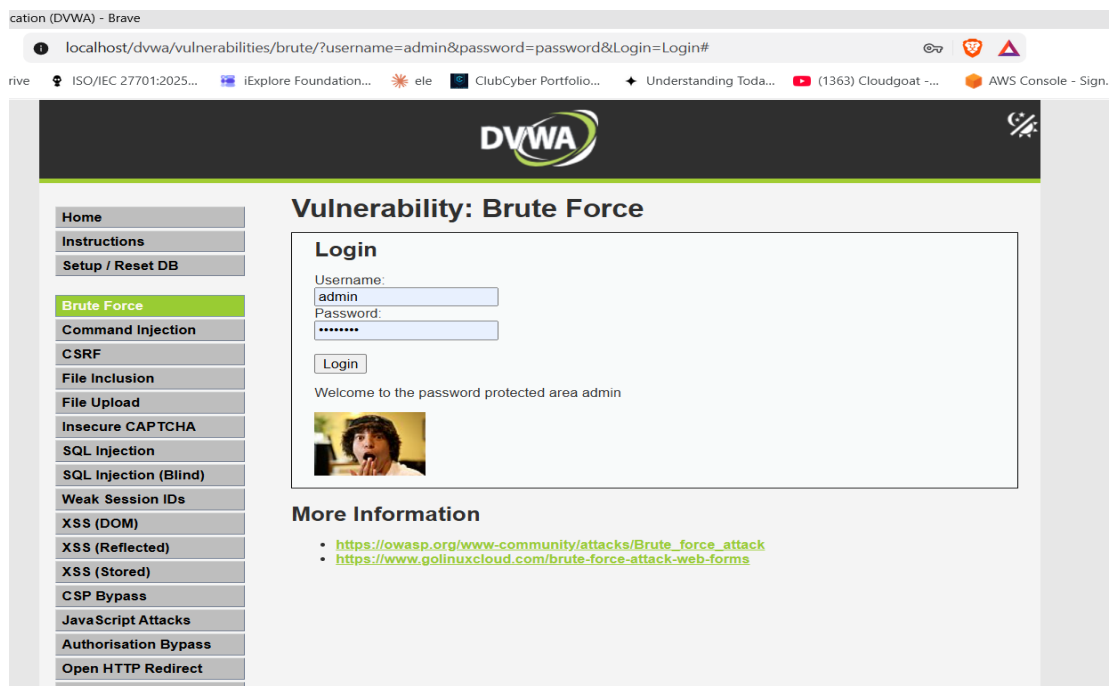


Figure 3: DVWA Brute Force — successful login with admin:password; "Welcome to the password protected area admin" confirmed

3.5 Extracted Credentials Summary

Parameter	Value	Source
Target URL	localhost/dvwa/vulnerabilities/brute/	DVWA Lab
Username	Admin	Known / Wordlist
Password Found	Password	rockyou.txt
HTTP Method	GET	Observed in URL
Tool Used	Hydra + Burp Suite	Kali Linux / Windows
Wordlist	rockyou.txt (14 million passwords)	/usr/share/wordlists/

4. Why Weak Passwords Are Dangerous

The DVWA brute force exercise demonstrated how "password" — one of the most common passwords in existence — was cracked almost instantly from a 14-million-entry wordlist. This has severe real-world implications:

4.1 Speed of Modern Attacks

- Hydra can attempt hundreds to thousands of passwords per second online
- Offline attacks (against leaked hash files) can test billions per second with GPU acceleration
- "password", "123456", "admin" are typically found within the first 100 attempts
- Even "complex-looking" passwords based on dictionary words (p@ssw0rd) are in wordlists

4.2 Real-World Consequences

- Complete account takeover — attacker gains full access to the victim's account
- Lateral movement — one compromised account can lead to network-wide access
- Data breach — all data accessible to that account is exposed
- Financial loss — banking, payment, and business accounts are prime targets
- Reputational damage — especially severe for organizations

4.3 Credential Stuffing

When passwords are reused across multiple sites, a single breach enables attackers to try the same credentials everywhere — known as credential stuffing. `rockyou.txt` itself originated from a real breach, showing that millions of users had their passwords exposed.

5. Defense — How to Prevent Brute Force Attacks

Defense Mechanism	Description	Effectiveness
Account Lockout	Lock account after N failed attempts	High
Strong Password Policy	Min 12 chars, mixed case, symbols, numbers	High
Multi-Factor Authentication	Require OTP/authenticator in addition to password	Very High
CAPTCHA	Prevent automated login attempts	Medium
Rate Limiting	Limit login requests per IP per minute	High
Password Hashing (bcrypt)	Slow hashing algorithm defeats offline cracking	High
IP Blacklisting	Block IPs with repeated failed logins	Medium

5.1 Strong Password Policy (Most Important)

Organizations must enforce password policies that make brute force computationally infeasible:

- Minimum 12 characters length
- Mix of uppercase, lowercase, numbers, and special characters
- No dictionary words, names, or keyboard patterns (qwerty, 12345)
- No reuse of previous passwords
- Regular password rotation (every 90 days for privileged accounts)

Example of a strong password vs weak password:

```
WEAK:    password, admin123, letmein
STRONG:  X7#mK9!pQr@2nL (randomly generated, 14 chars)
```

5.2 Multi-Factor Authentication (MFA)

MFA is the single most effective defense against brute force and credential theft. Even if an attacker obtains the correct password, they cannot login without the second factor (OTP, authenticator app, hardware key). MFA should be mandatory for all privileged accounts.

5.3 Account Lockout Policy

Implement progressive lockout:

- Lock account for 15 minutes after 5 failed attempts
- Permanently lock after 10 failed attempts (require admin unlock)
- Alert the account owner via email when lockout occurs
- Log all failed login attempts for security monitoring

5.4 CAPTCHA Implementation

CAPTCHA (Completely Automated Public Turing test to tell Computers and Humans Apart) prevents automated tools like Hydra from making rapid requests. Modern CAPTCHA solutions (Google reCAPTCHA v3) are invisible to legitimate users but block bots effectively.

5.5 Secure Password Storage

Passwords must never be stored in plaintext or using weak algorithms (MD5, SHA1):

```
INSECURE: MD5("password") = 5f4dcc3b5aa765d61d8327deb882cf99
SECURE:   bcrypt("password", cost=12) = $2b$12$... (slow, salted)
```

bcrypt and Argon2 are slow by design — making offline cracking computationally expensive even with leaked hashes.

6. Conclusion

This task demonstrated the real-world effectiveness of brute force attacks against systems with weak password policies. Using Hydra with the rockyou.txt wordlist, the DVWA admin account was compromised using the password "password" — one of the most commonly used passwords globally.

Key takeaways:

- Brute force attacks are trivially easy against accounts with weak or common passwords
- rockyou.txt contains 14+ million real passwords — if yours is in it, it will be found
- DVWA at Low security has no lockout, no CAPTCHA, no rate limiting — mirroring real legacy systems
- Credentials transmitted via GET parameters (visible in URL) are an additional vulnerability
- MFA + strong password policy + account lockout together make brute force attacks practically infeasible
- Password managers should be used to generate and store truly random, unique passwords

All testing was performed exclusively in a controlled, isolated DVWA lab environment for educational purposes only.